

Incident Response Plan, Playbook and Policy

MediHealth Solutions Inc.

Toronto, Ontario · Ransomware Attack · NIST Incident Response Lifecycle

PREPARED BY Marco Helie

CONTENTS

1. Executive Summary

2. Incident Response Playbook

- › Ransomware Attack — NIST Incident Response Lifecycle
- › Escalation Points
- › Stakeholders to Notify
- › Information Restrictions

3. Cybersecurity Policy Document

- › Policy 1 — Data Collection and Retention
- › Policy 2 — Acceptable Use
- › Policy 3 — Incident Response Activation

4. References

01 EXECUTIVE SUMMARY

This project outlines a comprehensive cybersecurity incident response strategy for MediHealth Solutions Inc., a privately-owned healthcare IT services company based in Toronto, Ontario. The plan includes a custom ransomware incident response playbook aligned with the NIST Incident Response Lifecycle and supported by three integrated organizational policies: Data Collection and Retention, Acceptable Use, and Incident Response Activation.

These policies are activated at various points in the playbook lifecycle to ensure procedural consistency, compliance with regulations such as PHIPA, PIPEDA, and HIPAA, and to support timely communication with key stakeholders. This approach enhances the organization's resilience against cyber threats and ensures that legal, operational, and reputational risks are minimized.

Consequences of non-compliance with these policies are clearly defined to ensure accountability and to promote a culture of cybersecurity awareness across the organization.

The accompanying materials include a detailed incident response playbook, a formal policy document, and a slideshow to communicate these concepts effectively to non-technical stakeholders. All content is based on industry best practices and is cited accordingly.

02 INCIDENT RESPONSE PLAYBOOK

Ransomware Attack

ORGANIZATION	MediHealth Solutions Inc.
INCIDENT TYPE	Ransomware Attack
FRAMEWORK USED	NIST Incident Response Lifecycle

STEP 1 — PREPARATION

- Conduct employee phishing training every 6 months.
- Maintain daily encrypted backups stored offsite and tested weekly.
- Establish a cybersecurity incident response team (CSIRT).
- Use endpoint detection and response (EDR) tools and monitor with SIEM.
- Activate Acceptable Use and Data Collection policies.

STEP 2 — DETECTION & ANALYSIS

- Indicators of compromise:
 - Unusual encryption file extensions (e.g., .locked, .crypt)
 - Sudden high CPU/disk activity
 - Files being renamed or locked
- Immediate actions:
 - Alert IT Security and CISO
 - Quarantine affected devices
 - Perform forensic capture of logs and memory
- Data Collection Policy is enforced during log and traffic capture.

STEP 3 — CONTAINMENT, ERADICATION & RECOVERY

- Isolate infected systems from the network.

- Block known malicious IPs and file hashes.
- Eradicate malware using antivirus and endpoint tools.
- Restore data from clean backups after ensuring the threat is neutralized.
- Notify Legal, Compliance, and PR teams.
- Retain logs for at least 12 months for investigation.

STEP 4 — POST-INCIDENT ACTIVITIES

- Conduct a post-mortem review.
- Update the playbook and policies based on findings.
- Submit breach report to regulators within 72 hours (PHIPA/PIPEDA).
- Notify patients if personal health information was compromised.
- Recommend policy or process improvements.
- Incident Response Activation Policy governs final reporting and updates.

Escalation Points

LEVEL	TRIGGER	ESCALATE TO
1	Initial alert	IT Security
2	Confirmed ransomware	CISO
3	Systems spreading / critical data impacted	CIO
4	Legal breach	Legal Counsel
5	Public disclosure required	Public Relations

Stakeholders to Notify

STAKEHOLDER	REASON FOR NOTIFICATION
CIO	Overall system impact and executive decision-making.
CISO	Coordinates technical response.
Legal Counsel	Compliance with PHIPA/PIPEDA/HIPAA.
Public Relations	External messaging and press management.
Compliance Officer	Regulatory documentation.
Clients	Personal notification of breach and steps taken.
Law Enforcement	If attack origin is criminal in nature.

Information Restrictions

DO NOT SHARE

- Specific system vulnerabilities
- Details of internal security controls
- Information about third-party vendors not involved in incident

03 CYBERSECURITY POLICY DOCUMENT

Policy 1 — Data Collection and Retention

PURPOSE	Ensure all personal and health data is collected lawfully and retained only as long as required.
SCOPE	Applies to all departments accessing or storing patient or employee data.

DETAILS

- Data must be collected with documented consent.
- Personal and health data is retained for 10 years post-service.
- Data related to security incidents must be stored for 12 months minimum.
- Access to collected data is role-based and logged.

NON-COMPLIANCE CONSEQUENCES

- Verbal/written warnings
- Job termination for repeat or severe violations
- Report to privacy regulators or legal authorities

Policy 2 — Acceptable Use

PURPOSE	Define acceptable behaviors for IT system usage.
SCOPE	All staff, contractors, and vendors using MediHealth IT resources.

DETAILS

- Access only systems and data required for job duties.
- No installation of unauthorized software.
- Do not bypass security tools (VPN, MFA, firewalls).
- Use work email/accounts for official purposes only.

NON-COMPLIANCE CONSEQUENCES

- Temporary or permanent access restrictions
- Disciplinary measures up to termination
- Potential legal action if data is misused or leaked

Policy 3 — Incident Response Activation

PURPOSE	Clarify triggers and procedures for formally activating incident response.
SCOPE	IT Security Team, Management, and Designated Stakeholders.

DETAILS

- Any confirmed or suspected cybersecurity incident triggers activation.
- CISO approves formal response escalation.
- Notification within 1 hour of detection to the CIRT and leadership.
- Stakeholder communication plan is initiated.

NON-COMPLIANCE CONSEQUENCES

- Delays in reporting may result in regulatory penalties.
- Written reprimands or termination for not reporting known breaches.
- Legal liabilities if data exposure is prolonged due to inaction.

04 REFERENCES

1. Cybersecure Canada. (2024). *Develop an Incident Response Plan: Fillable Template and Example*. Retrieved from:
<https://ised-isde.canada.ca/site/cybersecure-canada/en/certification-tools/develop-incident-response-plan-fillable-template-and-example>
2. CISA. (2024). *Federal Government Cybersecurity Incident and Vulnerability Response Playbooks*. Retrieved from:
https://www.cisa.gov/sites/default/files/2024-08/Federal_Government_Cybersecurity_Incident_and_Vulnerability_Response_Playbooks_508C.pdf
3. NIST. (2024). *Computer Security Incident Handling Guide (SP 800-61r2)*. Retrieved from:
<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>
4. FRSecure. (2020). *Incident Response Plan Template*. Retrieved from:
<https://frsecure.com/incident-response-plan-template/>